



## ■ Pruebas de penetración

---

- 2.2.1 Explotación de Sistemas Operativos

# Contenidos

- Sistemas operativos.
- Explotación de sistemas operativos.
- Técnicas de explotación.
- Cracking de contraseñas.

A black and white photograph of a man in a suit standing in a modern office, holding a tablet and smiling. The office has glass partitions and modern lighting. A blue square is visible in the upper right area of the image.

01

## Vulnerabilidades en sistemas operativos

# Sistemas operativos

Un sistema operativo (SO) es el software que actúa como interfaz entre el hardware de un ordenador y los usuarios, gestionando recursos y facilitando la ejecución de programas. Los sistemas operativos más comunes incluyen Windows, Linux, macOS, y sistemas para dispositivos móviles como Android e iOS.

Su función principal es:

- Administrar recursos de hardware (CPU, memoria, almacenamiento, dispositivos de entrada/salida).
- Proveer servicios para la ejecución de aplicaciones.
- Garantizar una experiencia de usuario fluida y eficiente.

# Importancia de la seguridad en sistemas operativos

Los sistemas operativos son el núcleo de cualquier dispositivo, y su seguridad es esencial para proteger datos, aplicaciones y recursos. Una vulnerabilidad en un SO puede ser explotada para:

- Obtener acceso no autorizado.
- Comprometer la integridad y disponibilidad del sistema.
- Robar información confidencial o causar daños irreparables.

Por ello, asegurar el SO implica:

- Mantenerlo actualizado con parches de seguridad.
- Configurar adecuadamente sus opciones de seguridad.
- Implementar controles para proteger contra ataques internos y externos.

# Explotación en sistemas operativos

La explotación en ciberseguridad se refiere al uso de vulnerabilidades en software, hardware o configuraciones para ejecutar acciones maliciosas. En el contexto de los sistemas operativos esto incluye:

- Acceso no autorizado a privilegios administrativos.
- Ejecución de código malicioso para tomar control del sistema.
- Interrupción de servicios o extracción de datos confidenciales.

Las explotaciones suelen realizarse mediante:

- Herramientas automatizadas (como frameworks de exploits).
- Ingeniería inversa para descubrir fallos en el sistema.
- Técnicas avanzadas como inyecciones de código o manipulación de memoria.

A black and white photograph of a man and a woman in a modern office setting. The man, on the left, is wearing a light-colored button-down shirt and dark trousers. The woman, on the right, is wearing a dark blazer over a light-colored turtleneck. They are both looking at a tablet held by the man. In the background, there are office desks, computer monitors, and a person sitting at a desk. The overall atmosphere is professional and collaborative.

02

## Explotación de vulnerabilidades

## Explotación de vulnerabilidades

## Explotación de vulnerabilidades

Es el proceso mediante el cual un atacante aprovecha debilidades, fallos o errores en un sistema informático, software, hardware o red para realizar actividades maliciosas. Estas vulnerabilidades pueden existir debido a errores de programación, configuraciones incorrectas, o incluso debido a un diseño deficiente.

Sitio de búsqueda de exploits:

<https://www.exploit-db.com/>

<https://www.cvedetails.com/>

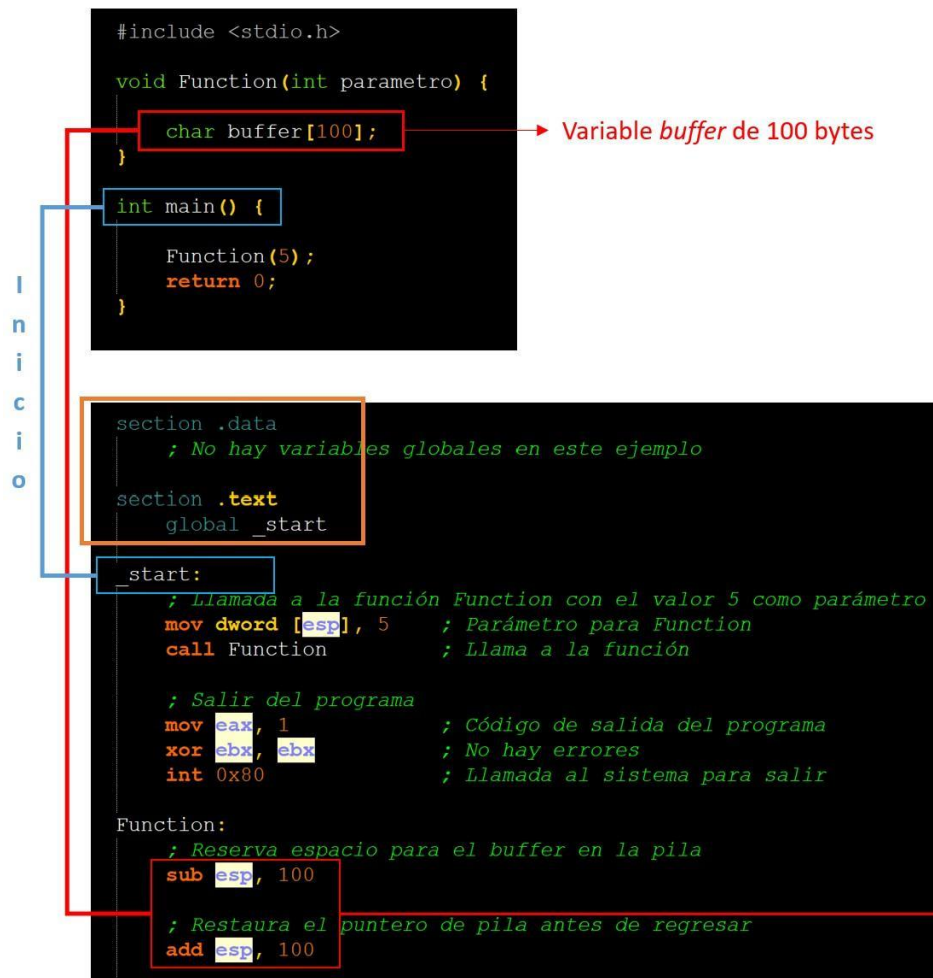
## Explotación de vulnerabilidades

# Técnicas de explotación de vulnerabilidades

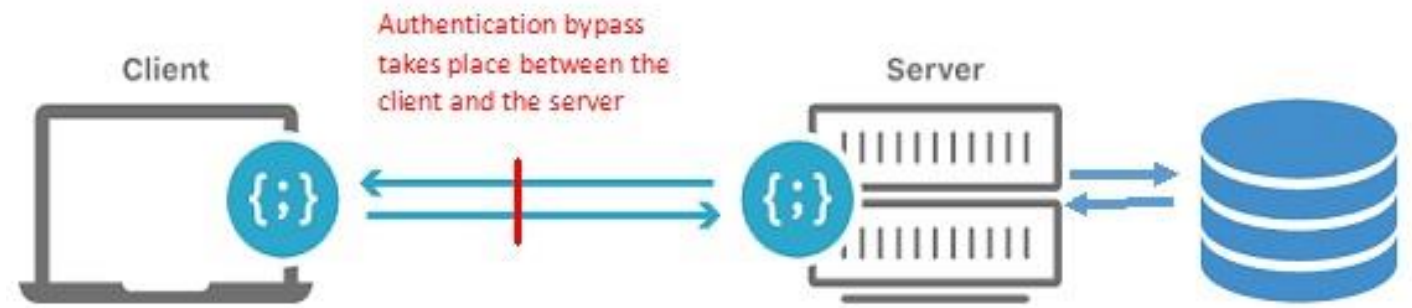
A continuación, se describen algunas de las técnicas más comunes utilizadas para explotar vulnerabilidades en sistemas y aplicaciones.

- **Desbordamiento de Buffer** (Buffer Overflow): Ocurre cuando un programa escribe más datos en un buffer de los que puede contener, sobrescribiendo así la memoria adyacente.
- **Remote Code Execution** (RCE) : Ejecución de código arbitrario en un sistema remoto, debido a una vulnerabilidad en el software
- **Bypass de Autenticación**: Acceso no autorizado a un sistema, eludiendo los mecanismos de autenticación.

# Buffer Overflow

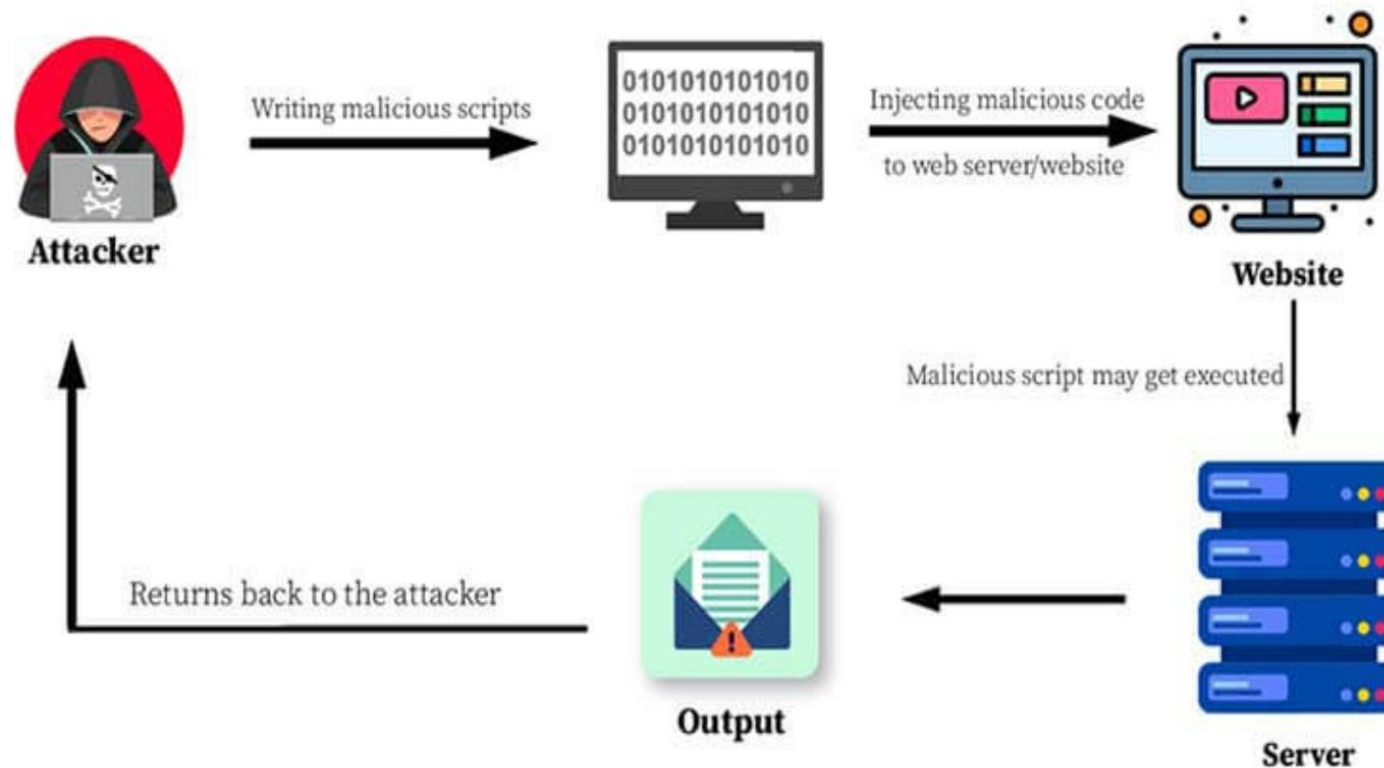


# Bypass de Autenticación



# Remote Code Execution

## Técnicas de explotación de vulnerabilidades (RCE)



# Metasploit

## Herramientas de hacking

Metasploit es una plataforma de pruebas de penetración y desarrollo de exploits ampliamente utilizada por profesionales de seguridad y hackers éticos para identificar, validar y explotar vulnerabilidades en sistemas informáticos. Desarrollada originalmente por H.D. Moore en 2003, Metasploit ha evolucionado para convertirse en una herramienta fundamental en el arsenal de cualquier experto en seguridad cibernética.

### **Metasploit Framework:**

La versión de código abierto de Metasploit, ampliamente utilizada por la comunidad de seguridad para desarrollar y probar exploits, ofrece un conjunto completo de herramientas para realizar pruebas de penetración, incluyendo un lenguaje de scripting propio (Meterpreter) y soporte para scripts en Ruby.

# Metasploit

## Herramientas de hacking

Principales funcionalidades de Metasploit

- Escaneo y descubrimiento de vulnerabilidades:
  - Utiliza módulos auxiliares para identificar vulnerabilidades en sistemas y aplicaciones.
- Desarrollo y pruebas de Exploits:
  - Permite a los usuarios desarrollar y probar nuevos exploits en un entorno controlado.
- Post-explotación
  - Realizar acciones en el sistema comprometido después de una explotación exitosa, como la escalada de privilegios, movimiento lateral, y exfiltración de datos.
- Automatización de pruebas:
  - Permite automatizar pruebas de penetración repetitivas y programar tareas.

# Metasploit

```
Trace program: running

wake up, Neo...
the matrix has you
follow the white rabbit.

knock, knock, Neo.

https://metasploit.com

=[ metasploit v6.0.30-dev ]
+ -- --[ 2099 exploits - 1129 auxiliary - 357 post ]
+ -- --[ 592 payloads - 45 encoders - 10 nops ]
+ -- --[ 7 evasion ]

Metasploit tip: Enable verbose logging with set VERBOSE
true

msf6 > 
```



03

## Cracking de contraseñas

# Password cracking:

Consiste en la recuperación de contraseñas desde data cifrada u ofuscada, a través de técnicas alternativas a la autenticación tradicional.

Las principales técnicas utilizadas para este efecto son:

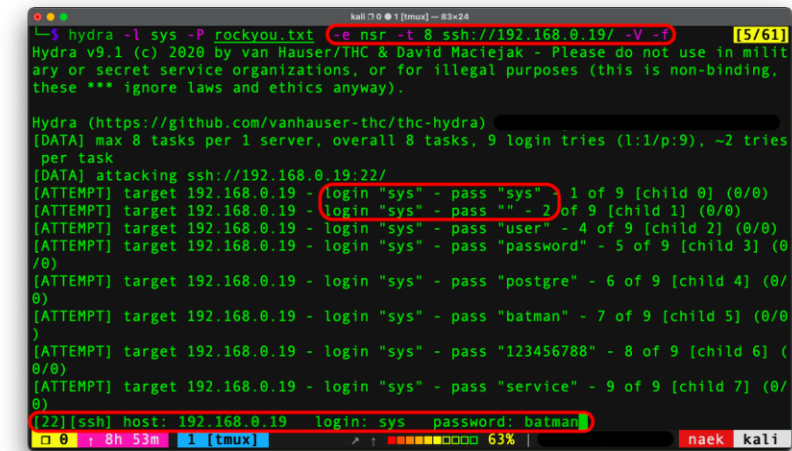
- **Ataque de diccionario:** que intenta probar muchas combinaciones de contraseñas establecidas en una base de datos.
- **Ataque de fuerza bruta:** que intenta probar combinaciones de caracteres a una alta tasa, hasta obtener la contraseña.

# Ataque de diccionario

Es un método para descifrar contraseñas, probando combinaciones predefinidas de palabras comunes, frases o términos almacenados en un archivo llamado **diccionario**.

Los atacantes asumen que los usuarios suelen utilizar contraseñas sencillas o palabras comunes.

Es más rápido que un ataque de fuerza bruta porque no prueba todas las combinaciones posibles, sino solo palabras probables.



```
kali@kali:~$ hydra -l sys -P rockyou.txt -e nsr -t 8 ssh://192.168.0.19/ -V -t [5/61]
Hydra v9.1 (c) 2020 by van Hauser/THC & David Maciejak - Please do not use in milit
ary or secret service organizations, or for illegal purposes (this is non-binding,
these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra)
[DATA] max 8 tasks per 1 server, overall 8 tasks, 9 login tries (1:1/p:9), ~2 tries
per task
[DATA] attacking ssh://192.168.0.19:22/
[ATTEMPT] target 192.168.0.19 - login "sys" - pass "sys" - 1 of 9 [child 0] (0/0)
[ATTEMPT] target 192.168.0.19 - login "sys" - pass " " - 2 of 9 [child 1] (0/0)
[ATTEMPT] target 192.168.0.19 - login "sys" - pass "user" - 4 of 9 [child 2] (0/0)
[ATTEMPT] target 192.168.0.19 - login "sys" - pass "password" - 5 of 9 [child 3] (0
/0)
[ATTEMPT] target 192.168.0.19 - login "sys" - pass "postgre" - 6 of 9 [child 4] (0/
0)
[ATTEMPT] target 192.168.0.19 - login "sys" - pass "batman" - 7 of 9 [child 5] (0/0
)
[ATTEMPT] target 192.168.0.19 - login "sys" - pass "123456788" - 8 of 9 [child 6] (
0/0)
[ATTEMPT] target 192.168.0.19 - login "sys" - pass "service" - 9 of 9 [child 7] (0/
0)
(22)[ssh] host: 192.168.0.19 login: sys password: batman
```

# Ataque de fuerza bruta

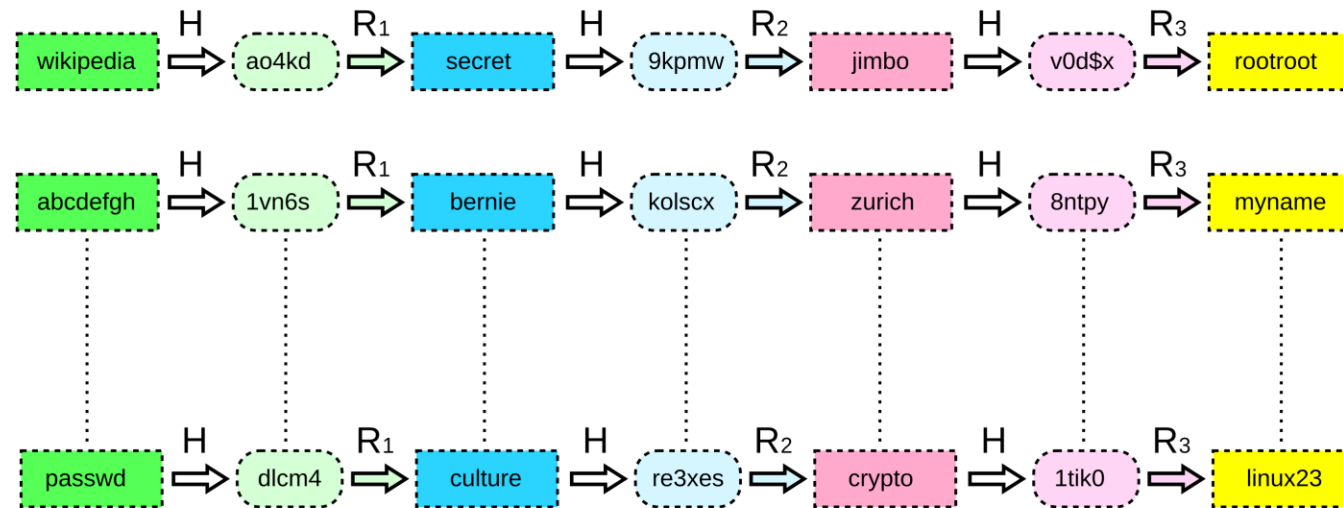
Es un método de descifrado en el que un atacante prueba **todas las combinaciones posibles** de contraseñas hasta encontrar la correcta. Se basa en un enfoque exhaustivo, pero es lento y requiere muchos recursos, especialmente para contraseñas largas o complejas.

- Efectivo contra contraseñas simples o cortas.
- Utiliza herramientas automatizadas para probar combinaciones rápidamente.
- Factores como el tamaño del conjunto de caracteres y la longitud de la contraseña determinan el tiempo requerido.



# Ataque rainbow

El ataque de tablas rainbow es un método utilizado para recuperar contraseñas a partir de valores hash. En lugar de intentar adivinar contraseñas mediante fuerza bruta o ataques de diccionario, este enfoque se basa en **tablas precomputadas** que permiten encontrar rápidamente la contraseña original correspondiente a un hash dado.



# Ataque Rainbow

## Uso de sal (salting):

- Añadir un valor único a cada contraseña antes de hashearla.

## Algoritmos robustos:

- Implementar algoritmos como bcrypt o Argon2, diseñados para resistir estos ataques.

## Contraseñas seguras:

- Fomentar contraseñas largas y complejas.

## Parches y cifrado adicional:

- Mantener los sistemas actualizados y usar cifrado además de hashing.

# Contraseñas por defecto

Uno de los problemas de ciberseguridad más relevantes es el uso de contraseñas por defecto por parte de usuarios y administradores de sistemas. Hoy existen sitios que contienen cientos de contraseñas por defecto de la mayoría de las aplicaciones y dispositivos utilizados en Sistemas Informáticos.

## **Impacto:**

- Los atacantes pueden obtener acceso a dispositivos o sistemas si los usuarios no cambian las contraseñas por defecto.
- Común en routers, cámaras IP, sistemas IoT y software recién instalado.



04

## Conclusiones

# Conclusiones

- Los sistemas operativos deben mantenerse actualizados y configurados correctamente para evitar ataques.
- Fallos como desbordamiento de búfer o ejecución remota son objetivos frecuentes de explotación.
- Metasploit es esencial para pruebas de penetración y análisis de vulnerabilidades.
- El uso de contraseñas fuertes y técnicas como el salting mitiga ataques de fuerza bruta y diccionario.

# DuocUC<sup>®</sup>

CERCANÍA. LIDERAZGO. FUTURO.

(**duoc.cl**)

**7 AÑOS**  
ACREDITADO



DESDE AGOSTO 2017 HASTA AGOSTO 2024.  
DOCENCIA DE PREGRADO. GESTIÓN  
INSTITUCIONAL. VINCULACIÓN CON EL MEDIO.